

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (CVSS-weighted risk ranking) · Generated 2026-06-19 · SHA: `61ed8c3` · Model: $0.5 \times \text{CVE_severity} + 0.3 \times \text{exposure} + 0.2 \times \text{criticality}$

Ranked remediation backlog

#	Coordinate	Ver	Band	Risk Score	Top CVE	CVSS	Fix Version
1	org.apache.logging.log4j:log4j-core	2.14.1	CRITICAL	9.0	CVE-2021-44228	10.0	2.17.2
2	com.fasterxml.jackson.core:jackson-databind	2.9.8	CRITICAL	8.4	CVE-2019-14379	9.8	2.14.0
3	org.apache.logging.log4j:log4j-api	2.14.1	CRITICAL	8.0	CVE-2026-34479	7.5	2.17.2
4	mysql:mysql-connector-java	8.0.30	CRITICAL	8.0	CVE-2023-22102	8.3	8.0.33
5	com.google.protobuf:protobuf-java	3.19.4	HIGH	6.9	CVE-2024-7254	7.5	3.25.3
6	com.google.guava:guava	24.1.1-jre	HIGH	6.6	CVE-2023-2976	7.1	32.1.1-jre
7	com.fasterxml.jackson.core:jackson-annotations	2.9.0	MEDIUM	5.7	CVE-2018-1000873	6.5	2.14.0
8	commons-io:commons-io	2.4	MEDIUM	5.7	CVE-2021-29425	4.8	2.15.1
9	org.apache.commons:commons-lang3	3.4	MEDIUM	5.3	CVE-2025-48924	5.3	3.17.0
10	com.fastxml.jackson.core:jackson-databind	2.9.8	MEDIUM	3.4	TYPOSQUAT	—	REMOVE
11	com.fasterxml.jackson.core:jackson-core	2.9.8	LOW	2.1	—	—	2.14.0
12	org.junit.jupiter:junit-jupiter	5.10.2	LOW	1.2	—	—	6.1.0
13–24	(other test/utility deps)	—	LOW	≤1.8	—	—	—

Component scores — top-ranked items

Dependency	CVE Severity (0–10)	Exposure (0–10)	Business Criticality (0–10)	Weighted Risk
log4j-core:2.14.1	10.0	8.0	8.0	9.0
jackson-databind:2.9.8	10.0	8.0	5.0	8.4
log4j-api:2.14.1	4.5	8.0	8.0	8.0
mysql-connector-java:8.0.30	8.3	8.0	7.0	8.0
protobuf-java:3.19.4	9.0	5.0	3.0	6.9
guava:24.1.1-jre	7.6	8.0	4.0	6.6
jackson-annotations:2.9.0	6.5	5.0	3.0	5.7
commons-io:2.4	5.3	8.0	3.0	5.7
commons-lang3:3.4	5.3	8.0	3.0	5.3

Scoring rationale

log4j-core:2.14.1 — CVE severity 10.0 (Log4Shell CVSS 10.0 with density bonus for 8 CVEs). Direct compile dep (+4), compile scope (+3), network/logging library (+1) = exposure 8.0. Used directly in `DiscountCalculator.java` inside an invoice/payment service = criticality 8.0. Final: $0.5 \times 10.0 + 0.3 \times 8.0 + 0.2 \times 8.0 = 9.0$.

jackson-databind:2.9.8 — CVE severity capped at 10.0 (14 CRITICAL CVEs at 9.8 + density bonus). Direct compile dep, serialization library = exposure 8.0. API/service layer usage = criticality 5.0. Final: $0.5 \times 10.0 + 0.3 \times 8.0 + 0.2 \times 5.0 = 8.4$.

mysql-connector-java:8.0.30 — CVE severity 8.3 (single HIGH CVE). Direct compile dep, data access library = exposure 8.0. Connects to database in invoice/payment service (PII + financial data) = criticality 7.0. Final: $0.5 \times 8.3 + 0.3 \times 8.0 + 0.2 \times 7.0 = 8.0$.

Band summary

Band	Count
CRITICAL	4
HIGH	2
MEDIUM	4
LOW	14

Priority recommendations

- P0 — REMOVE** the typosquatted dependency `com.fastxml.jackson.core:jackson-databind:2.9.8` from `pom.xml` (supply-chain confusion attack).
- P0 — Upgrade** `log4j-core + log4j-api 2.14.1` → **2.17.2** (Log4Shell CVE-2021-44228, CVSS 10.0 — actively exploited, used in payment code path).
- P0 — Upgrade** `jackson-databind 2.9.8` → **2.14.0** (54 CVEs including 14 CRITICAL RCE deserialization chains).
- P0 — Upgrade** `mysql-connector-java 8.0.30` → **8.0.33** (CVE-2023-22102, CVSS 8.3, database in PII context).
- P1 — Upgrade** `protobuf-java 3.19.4` → **3.25.3** (4 HIGH CVEs — transitive via mysql connector).
- P1 — Upgrade** `guava 24.1.1-jre` → **32.1.1-jre** (CVE-2023-2976 — note: major version jump, review API changes).
- P2 — Remove** the HTTP-only repository `http://insecure-mirror.example.net/maven2` from `pom.xml`.
- P3 — Upgrade** `commons-io 2.4` → `2.15.1`, `commons-lang3 3.4` → `3.17.0` (MEDIUM CVEs).

Build gate status

The build currently **FAILS** the JaCoCo 80% line-coverage gate (`mvn verify`). The deliberately uncovered branches in `DiscountCalculator.applyBulkBonus()` and `loyaltyPoints()` keep coverage below the minimum. Additionally, the typosquatted dependency causes `mvn dependency:tree` to fail without the HTTP blocker. These issues must be resolved before the build can pass.

Machine-readable source: `depscan-risk-report.json` (source_sha: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`). Ready for Auto-Remediation Skill (Stage 3) and PR Validation Agent (Stage 4).